Vendor Risk Summary

This document summarises the risk assessment for third-party processors used by the Platform Engineering group. It is reviewed each quarter by the Security Office and the Data Protection Officer.

Tiering

Vendors are placed in one of three tiers. Tier 1 vendors process Restricted data and require an annual on-site assessment. Tier 2 vendors process Internal data and require a security questionnaire every two years. Tier 3 vendors receive no company data and require only a signed terms of service.

Assessment findings

The primary cloud hosting vendor is Tier 1 and holds a current independent audit report. No critical findings are open.

The analytics vendor is Tier 2. Its questionnaire from the previous cycle lapsed in March, so a renewal is outstanding. Until the questionnaire is renewed, no new data may be shared with that vendor.

Continuous monitoring

Security ratings for all Tier 1 and Tier 2 vendors are monitored monthly. A drop in rating below the acceptable threshold opens an automatic review ticket assigned to the vendor owner.

Escalation and remediation

A vendor with an open critical finding must produce a remediation plan within 10 business days. If the plan is rejected, the vendor is suspended: existing integrations are switched to read-only and new data flows are blocked.

Termination of a vendor relationship requires confirmation that all company data has been deleted or returned, evidenced in writing, and recorded in the vendor register.